

Relatório de Critérios de Aceite — US-07 Papéis LGPD de ação única no fundo da hierarquia

Ticket GLPI #10141 · Evidência 100% automatizada (Pest) — feature sem UI própria

Gerado em: 30/07/2026

Spec: .planning/product/stories/US-07-add-ons-lgpd-exigem-posto-base.md

Commits: 560b923, 47b12ee, b81d565, e11356e

Ferramenta: Pest (100% automatizado — regra de backend puro, sem tela dedicada)

Ticket GLPI: #10141 — HU - #10141 Papéis LGPD de ação única no fundo da hierarquia

Branch: feature/papeis-lgpd-fundo-hierarquia (api/)

Ambiente: API Sail/PostgreSQL — Pest 4, memory_limit=1G

Resumo

8 critérios de aceite, todos verificados por suíte automatizada (Pest) — esta HU altera apenas regra de hierarquia de papéis e um comando de saneamento no backend, sem componente de UI próprio (o drawer de perfis que consome o erro 422 já existia e não muda). 96 testes relevantes rodados nesta passada, todos verdes. Inclui as duas correções feitas na revisão do PR #92 (bug de soft-delete no comando de saneamento e fechamento de um bypass real da RN02 via UserService::create/update, fora do escopo literal dos CAs mas necessário para o propósito da HU).

CA	CRITÉRIO	STATUS
CA01	Add-ons no fundo da hierarquia	ATENDIDO · automatizado
CA02	Empilhar add-on sobre posto continua permitido	ATENDIDO · automatizado
CA03	Add-on isolado é recusado (caminho de erro)	ATENDIDO · automatizado
CA04	Remover o último posto base é recusado (caminho de erro)	ATENDIDO · automatizado
CA05	Regra vale nos dois pontos de mutação	ATENDIDO · automatizado
CA06	Resolução de "o papel" fica correta por estrutura	ATENDIDO · automatizado
CA07	União de permissões preservada	ATENDIDO · automatizado
CA08	Base legada saneada	ATENDIDO · automatizado

CA01 — Add-ons no fundo da hierarquia ATENDIDO · automatizado

Critério (Gherkin): Dado o RoleSeeder executado Quando consulto os levels Então client_family_viewer = 910, client_territorial_qualifier = 920 e client_geo_panel_viewer = 930 E todos são > 900 e > client_operador (30).

Como foi testado: tests/Feature/Database/RoleSeederTest.php + verificação direta na base de dev real após db:seed --class=RoleSeeder.

Resultado observado:

- 4 testes verdes confirmando os 3 levels exatos e a faixa reservada 900+.
- Consulta real na base de dev (guard client, level >= 900): family_viewer=910, territorial_qualifier=920, geo_panel_viewer=930 — nenhum outro papel na faixa.

Evidência por cobertura automatizada — ver Anexo.

CA02 — Empilhar add-on sobre posto continua permitido ATENDIDO · automatizado

Critério (Gherkin): Dado um profissional com o posto operador Quando o Master atribui family_viewer Então a atribuição é aceita E o profissional passa a abrir o prontuário familiar detalhado.

Como foi testado: UserTenantRoleControllerTest (store) + ProfessionalRoleControllerTest (syncRoles).

Resultado observado:

- 'store aceita add-on empilhado sobre um posto base existente (CA02)' — verde.
- 'aceita empilhar um add-on sobre o posto base (CA02 — sem regressão)' — verde, união Spatie confirmada com operador + family_viewer.

Evidência por cobertura automatizada — ver Anexo.

CA03 — Add-on isolado é recusado (caminho de erro)

ATENDIDO · automatizado

Critério (Gherkin): Dado um profissional sem nenhum posto base no tenant Quando o Master tenta salvar um conjunto de perfis contendo apenas add-ons Então a operação é recusada com 422 e mensagem em pt-BR explicando a exigência E nenhuma linha é criada em user_tenant_role.

Como foi testado: UserTenantRoleControllerTest (store) + ProfessionalRoleControllerTest (syncRoles) + UserControllerTest (via /api/client/users, achado da revisão do PR #92).

Resultado observado:

- 'store recusa add-on isolado para usuário sem posto base no tenant (CA03)' — verde, assertDatabaseMissing + Spatie vazio.
- 'recusa um conjunto composto só por add-ons (CA03/CA05)' — verde, UTR/Spatie/activity_log inalterados.
- 'store rejeita criar user com add-on isolado como único role (RN02, GLPI #10141)' — verde, 422 via UserService::create — fecha o bypass encontrado na revisão do PR.

Evidência por cobertura automatizada — ver Anexo.

CA04 — Remover o último posto base é recusado (caminho de erro)

ATENDIDO · automatizado

Critério (Gherkin): Dado um profissional com operador + family_viewer Quando o Master remove operador mantendo family_viewer Então a operação é recusada com 422 — o estado proibido do CA03 não pode ser alcançado por remoção.

Como foi testado: UserTenantRoleControllerTest (destroy/destroyForUser/update) + ProfessionalRoleControllerTest (syncRoles) + UserControllerTest (update, achado da revisão).

Resultado observado:

- 'destroy recusa remover o último posto base mantendo um add-on (CA04)' — verde.
- 'destroyForUser recusa ...' — verde.
- 'update rejeita trocar o único role do target para um add-on isolado (RN02, GLPI #10141)' — verde, fecha o mesmo bypass via UserService::update.

Evidência por cobertura automatizada — ver Anexo.

CA05 — Regra vale nos dois pontos de mutação

ATENDIDO · automatizado

Critério (Gherkin): Dado que `user_tenant_role` é mutado tanto por `UserTenantRoleController` quanto por `ProfessionalService::syncRoles` Quando tento criar o estado proibido por qualquer um dos dois caminhos Então ambos recusam — a validação não pode viver só no drawer de perfis.

Como foi testado: Verificação estrutural + testes cruzados: um único método

(`UserTenantRoleSyncService::assertResultingSetHasBasePost()`) chamado pelos dois pontos do ticket.

Resultado observado:

- Confirmado por leitura de código: implementação única, sem duplicação de regra.
- Ambos os caminhos devolvem a mesma chave de mensagem (`user_tenant_role.validation.base_post_required`), asserido nos dois arquivos de teste.
- Achado adicional na revisão do PR #92 (fora do escopo literal deste CA, mas do mesmo espírito): o mesmo método também passou a ser chamado por `UserService::create/update`, terceiro ponto de mutação que não constava nos CAs originais mas permitia o mesmo estado proibido por outro caminho — fechado e testado (ver CA03/CA04).

Evidência por cobertura automatizada — ver Anexo.

CA06 — Resolução de "o papel" fica correta por estrutura

ATENDIDO · automatizado

Critério (Gherkin): Dado um profissional com operador (30) + `family_viewer` (910) Quando consulto `/auth/me`, o seletor de tenants e a hierarquia de CRUD Então o papel resolvido é operador nos três E as exclusões por nome permanecem no código, com os testes de regressão das HUs #9760/#9761 verdes.

Como foi testado: `FamilyAccessServiceTest`, `RoleServiceTest`, `TenantServiceTest`,

`ClientUserPolicyStackedRolesTest` — nenhum código de produção destes pontos foi alterado (só o level mudou).

Resultado observado:

- 19 testes de regressão verdes, sem alteração de `ClientUserPolicy::roleFor/TenantService::listForUser/TenantPermissionResolver`.
- Exclusão por nome (`RoleCode::addOnRoleNames()`) confirmada intacta e ainda necessária como defesa em profundidade independente do valor numérico do level.

Evidência por cobertura automatizada — ver Anexo.

CA07 — União de permissões preservada ATENDIDO · automatizado

Critério (Gherkin): Dado o mesmo profissional Quando o TenantPermissionResolver calcula as permissões efetivas Então families.view-details continua concedida — add-on entra na união de permissões, muda apenas a posição na hierarquia.

Como foi testado: tests/Unit/Services/TenantPermissionResolverTest.php.

Resultado observado:

- 6 testes verdes; união de permissões de papéis empilhados confirmada sem deduplicação indevida.
- Ordem de agrupamento por level ajustada (posto base antes do add-on) — efeito esperado e desejado da RN01, sem mudança de código de produção do resolver.

Evidência por cobertura automatizada — ver Anexo.

CA08 — Base legada saneada ATENDIDO · automatizado

Critério (Gherkin): Dado profissionais existentes que hoje possuem apenas um add-on Quando executo o comando de saneamento antes da migração de levels Então cada caso é listado com tenant, CPF mascarado e papel E nenhum usuário perde acesso silenciosamente nem fica impedido de autenticar.

Como foi testado: tests/Feature/Console/AuditAddonOnlyRolesCommandTest.php (8 testes, incluindo o caso de soft-delete corrigido na revisão) + execução real do comando roles:audit-addon-only na base de dev.

Resultado observado:

- 8 testes verdes: listagem, mascaramento de CPF (só 2 últimos dígitos), escopo por tenant, soft-delete corretamente ignorado, prova de somente-leitura (snapshot antes/depois idêntico).
- Achado da revisão do PR #92: o comando usava withoutGlobalScopes() (removia também o SoftDeletingScope), o que poderia mascarar uma violação real se um posto base fosse soft-deletado deixando só o add-on ativo — corrigido para withoutGlobalScope(BelongsToTenantScope::class); novo teste discrimina esse caso.
- Execução real na base de dev (após o fix): 2 casos encontrados — Maceió Geo e Arapiraca Geo, ambos com apenas geo_panel_viewer — nenhum registro alterado. Pendência operacional: tratar esses 2 casos com produto/operação antes do deploy do RoleSeeder atualizado.

Evidência por cobertura automatizada — ver Anexo.

Anexo — Suíte Pest completa dos arquivos relevantes aos 8 CAs (96 testes, 260 assertions)

```
PASS Tests\Feature\Database\RoleSeederTest
✓ it coloca os add-ons LGPD nos levels 910/920/930 (CA01) 0.31s
✓ it mantém todo add-on acima de 900 e abaixo do operador na hierarqu... 0.01s
✓ it nao deixa nenhum posto real na faixa reservada aos add-ons (CA01... 0.01s
✓ it reaplica os novos levels a papeis pre-existentis (re-seed idempo... 0.02s
```

```

PASS Tests\Unit\Services\Client\UserTenantRoleSyncServiceTest
✓ it aceita conjunto vazio - "sem papel algum" nao e o estado proibid... 0.02s
✓ it aceita conjunto so com posto base (RN02) 0.01s
✓ it aceita add-on empilhado sobre posto base (CA02) 0.01s
✓ it rejeita conjunto composto so por add-ons (CA03) 0.01s
✓ it rejeita conjunto com varios add-ons e nenhum posto base (CA03) 0.01s
✓ it aceita nomes de papel alem de models (mesma decisao) 0.01s
✓ it activeRolesFor devolve so os papeis ativos do usuario naquele te... 0.04s
✓ it activeRolesFor devolve colecao vazia quando o usuario nao tem vi... 0.01s

```

```

PASS Tests\Feature\Api\UserTenantRoleControllerTest
✓ it creates a user tenant role binding 0.04s
✓ it allows the same user to have multiple roles in the same tenant 0.02s
✓ it rejects a duplicate (user, tenant, role) 0.01s
✓ it rejects binding when user is a manager 0.01s
✓ it rejects binding when role guard is not client 0.01s
✓ it lists tenant-role bindings for a specific user (admin scope) 0.02s
✓ it deletes a tenant-role binding (admin scope, nested route) 0.01s
✓ it creates a tenant-role binding via nested route 0.01s
✓ it rejects nested-route delete when binding belongs to another user 0.01s
✓ it validates required fields 0.01s
✓ it requires authentication 0.01s
✓ it store sincroniza model_has_roles do usuario com o UTR criado 0.01s
✓ it store acumula roles no model_has_roles quando user tem multiplos... 0.02s
✓ it store recusa add-on isolado para usuario sem posto base no tenan... 0.01s
✓ it store aceita add-on empilhado sobre um posto base existente (CA0... 0.01s
✓ it store avalia o posto base por tenant, nao globalmente (CA03) 0.01s
✓ it update recusa trocar o unico posto base por um add-on (CA04) 0.02s
✓ it update aceita trocar um add-on por outro papel quando o posto ba... 0.02s
✓ it destroy recusa remover o ultimo posto base mantendo um add-on (C... 0.01s
✓ it destroyForUser recusa remover o ultimo posto base mantendo um ad... 0.01s
✓ it destroy permite remover o add-on, deixando so o posto base (CA04... 0.01s
✓ it destroy permite esvaziar o conjunto (nenhum papel restante nao v... 0.01s
✓ it destroy via nested route remove o role do model_has_roles quando... 0.01s

```

```

PASS Tests\Feature\Api\Client\ProfessionalRoleControllerTest
✓ it lists current and assignable roles (CA01) 0.03s
✓ it syncs roles granting and revoking in diff (CA02/CA03) 0.02s
✓ it is idempotent when the same set is resent (RN04) 0.02s
✓ it revokes all roles when role_ids is empty (RN11) 0.02s
✓ it rejects assigning a role equal to or above the master hierarchy... 0.02s
✓ it rejects assigning an inactive role (RN02) 0.02s
✓ it returns 404 for a professional from another tenant 0.02s
✓ it aceita empilhar um add-on sobre o posto base (CA02 - sem regress... 0.02s
✓ it recusa um conjunto composto so por add-ons (CA03/CA05) 0.02s
✓ it recusa remover o ultimo posto base mantendo o add-on (CA04/CA05) 0.02s
✓ it continua permitindo revogar TODOS os perfis (conjunto vazio nao... 0.02s
✓ it forbids an operador from managing professional roles (MASTER-onl... 0.02s

```

```

PASS Tests\Feature\Api\Client\UserControllerTest
✓ it lista apenas usuarios com role hierarquicamente abaixo no tenant... 0.02s
✓ it nao lista usuarios de outros tenants 0.02s
✓ it store rejeita criar user com role hierarquicamente acima 0.01s
✓ it store rejeita criar user com role no mesmo level 0.02s
✓ it store aceita criar user com role abaixo e cria vinculo no tenant 0.02s
✓ it update rejeita promover target para role acima do meu 0.02s
✓ it store rejeita criar user com add-on isolado como unico role (RN0... 0.02s
✓ it update rejeita trocar o unico role do target para um add-on isol... 0.02s
✓ it destroy exige permission users.destroy 0.02s
✓ it destroy exige hierarquia mesmo com permission 0.02s
✓ it destroy permite com permission + hierarquia ok 0.02s
✓ it rejeita request sem header X-Tenant-UUID 0.01s

```

```

✓ it bloqueia manager autenticado no guard errado 0.01s
✓ it aplica filter[full_name] via query string 0.02s
✓ it respeita hierarquia mesmo quando filter casa user de role acima 0.02s
✓ it rejeita sort em campo nao permitido 0.02s

PASS Tests\Feature\Console\AuditAddonOnlyRolesCommandTest
✓ it lista o profissional que so tem add-ons, com tenant, CPF mascara... 0.02s
✓ it nao expoe o CPF completo - so os 2 ultimos digitos (LGPD) 0.01s
✓ it ignora quem tem posto base, mesmo com add-on empilhado 0.01s
✓ it avalia o conjunto por tenant - posto base em outro tenant nao sa... 0.01s
✓ it nao considera vinculos soft-deletados 0.01s
✓ it detecta violação quando só o posto base foi soft-deletado e o ad... 0.01s
✓ it e SOMENTE LEITURA: nao altera user_tenant_role, users nem grava... 0.01s
✓ it informa base integra quando nao ha nenhum vinculo 0.01s

PASS Tests\Unit\Services\FamilyAccessServiceTest
✓ it detects the master role only in the tenant where it was granted 0.02s
✓ it detects the view-details permission per tenant, via the dedicate... 0.02s
✓ it stops counting a revoked (force-deleted) role as a grant 0.02s
✓ it resolves the active professional and denies inactive/soft-delete... 0.02s

PASS Tests\Unit\Services\Client\RoleServiceTest
✓ it listAssignable retorna apenas roles abaixo do meu level no guard... 0.01s
✓ it listAssignable omite roles no mesmo level (estritamente menor) 0.01s
✓ it listAssignable ignora roles do guard manager/web 0.01s
✓ it listAssignable omite roles inativos (HU #9358 CA01) 0.01s
✓ it listAssignable 403 se user sem role no tenant 0.01s

PASS Tests\Unit\Services\Client\TenantServiceTest
✓ it listForUser retorna tenants vinculados ordenados por trade_name 0.01s
✓ it listForUser anexa currentRole (role do user naquele tenant) 0.01s
✓ it listForUser retorna collection vazia quando user nao tem vinculo... 0.01s
✓ it listForUser nao retorna tenants de outros users 0.01s
✓ it listForUser exclui tenants inativos da listagem (RN05/RN06) 0.01s
✓ it listForUser retorna collection vazia quando todos os vinculos sa... 0.01s

PASS Tests\Feature\Policies\ClientUserPolicyStackedRolesTest
✓ it resolves the SENIOR role (operador, level 30) even when the fami... 0.02s
✓ it resolves the SENIOR role even when the family_viewer add-on is i... 0.02s
✓ it an operador stacked with family_viewer still CANNOT create anoth... 0.02s
✓ it an operador stacked with family_viewer still CANNOT update anoth... 0.02s

PASS Tests\Unit\Services\TenantPermissionResolverTest
✓ it unions permissions of stacked roles in the same tenant without d... 0.02s
✓ it isolates the permission set between tenants (no cross-tenant uni... 0.02s
✓ it only resolves permissions of the client guard, never the manager... 0.02s
✓ it stops counting a revoked (force-deleted) binding as a grant 0.02s
✓ it groups bindings by tenant with roles and deduplicated permission... 0.02s
✓ it recognizes only registered client-guard permission names as scop... 0.02s

Tests: 96 passed (260 assertions)
Duration: 1.86s

```